Full-Security Labs 결과보고서

통합 보안 인프라 구축 및 침투 테스트

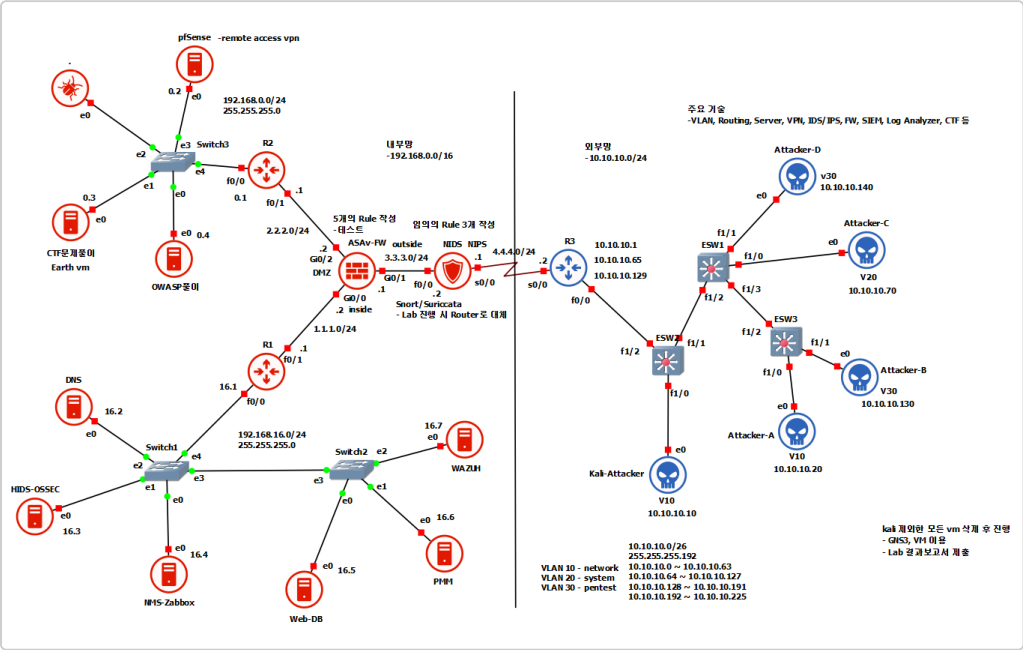
과제명	Full-Security Labs 통합 보안 인프라 구축 및 침투 테스트
작성일	2026-10-02
작성자	송우진
환경	GNS3 · VirtualBox · Ubuntu Server · FreeBSD(pfSense) · Kali
핵심 기술	VLAN · Routing · Server · VPN · NIDS · Firewall · SIEM · Log Analyzer · CTF

1. 개요 및 전체 구성

본 과제는 상반기에 학습한 보안 기술(VLAN·라우팅·서버 구축·VPN·IDS·방화벽·SIEM·로그분석·CTF)을 개별 실습으로 끝내지 않고 **하나의 통합 보안 인프라**로 묶어 실제 운영 환경에 가깝게 재현하는 것을 목표로 한다. 네트워크 계층(GNS3)과 서버 계층(VirtualBox)을 연결하여 내부망 서비스, 보안관제, 외부 공격자망을 동시에 구성하고, 각 보안 통제가 실제로 동작하는지를 반드시 로그·캡처로 확인하였다.

모든 작업은 **"구성 → 트래픽 발생 → 로그/캡처로 검증"** 을 한 사이클로 반복하는 것을 원칙으로 삼았다. 방화벽 룰은 설계 후 packet-tracer와 실제 트래픽으로 허용/차단을 교차 검증하고, NIDS 룰은 실제 ping·SSH·HTTP 트래픽을 발생시켜 탐지 로그로 확인하였으며, 서버 간 연동은 에이전트 등록 상태와 대시보드 수신으로 확인하였다.

구분	대역	설명 / VLAN(외부망)
내부망	192.168.16.0/24	서비스·보안관제 서버 및 게이트웨이 (단일 대역으로 통일)
외부망	10.10.10.0/24	공격자 VM — VLAN10 Network / VLAN20 System / VLAN30 Pentest
VPN 터널	172.16.0.0/24	pfSense OpenVPN 원격 접속 시 클라이언트에 할당되는 대역



전체 토폴로지 (내부망 서비스·보안관제 / 외부망 공격자 / ASAv-FW · Suricata 투명 브리지)

서버/장비 IP 대장

서버	IP	역할
DNS (BIND9)	192.168.16.91	정·역방향 도메인 해석 (+OSSEC·Zabbix 에이전트 호스트)
Web-DB	192.168.16.137	Apache+PHP+MariaDB (+WAZUH agent·PMM client·Log Analyzer)
WAZUH	192.168.16.221	SIEM/HIDS 매니저
HIDS-OSSEC	192.168.16.99	HIDS 에이전트(DNS에 배치) → WAZUH 연동
NMS-Zabbix	192.168.16.139	서버·시스템 통합 모니터링
PMM	192.168.16.201	DB 성능/쿼리 모니터링(Docker)
NIDS-Suricata	192.168.16.202	통과 트래픽 탐지(alert 전용)
pfSense	WAN 192.168.16.24 / LAN 10.10.10.254	Remote Access VPN
Kali / Earth VM	192.168.16.71 / .48	침투 테스트 / CTF 대상

> 에이전트 배치 전략: 모니터링 에이전트를 별도 서버가 아니라 **대상 서버에 직접** 올렸다. WAZUH agent·PMM client는 Web-DB(.137)에, OSSEC(HIDS)·Zabbix agent는 DNS(.91)에 설치하여 관리 대상과 수집 지점을 일치시켰다.

구축 진행 순서(방법론)

의존 관계를 고려해 아래 순서로 진행하였다. 이름 해석(DNS)을 먼저 마련하고, 서비스·관제·탐지·원격접속·침투 순으로 쌓아 올렸다.

1. GNS3 네트워크(VLAN·라우팅·ASAv) 구성 및 도달성 검증
2. DNS(BIND9) → Web-DB(LAMP) 등 기반 서비스 구축 및 도메인 등록
3. WAZUH(SIEM) 매니저 구축 후 Web-DB·DNS에 에이전트 배치, Zabbix·PMM 모니터링 연동
4. Web-DB에 Log Analyzer(중앙 로그) 구성, 각 서버 로그 수집
5. Suricata NIDS 투명 브리지 배치 및 탐지 룰 검증, pfSense 원격 VPN 구축
6. Kali로 침투 테스트(CTF) 수행 및 방화벽·NIDS 방어 검증

서버별 구축 요약

서버	주요 소프트웨어	역할	상태
DNS	BIND9	정·역방향 도메인 해석	완료
Web-DB	Apache+PHP+MariaDB	웹/DB 서비스, FW·IDS 테스트 대상	완료
WAZUH	Wazuh 4.x	SIEM/HIDS 매니저	완료
HIDS-OSSEC	OSSEC agent	DNS에 설치→WAZUH 연동	완료
NMS-Zabbix	Zabbix 7.0 LTS	서버·시스템 모니터링	완료
PMM	PMM 3 (Docker)	DB 성능/쿼리 모니터링	완료
NIDS-Suricata	Suricata	통과 트래픽 탐지(alert)	완료
pfSense	pfSense CE+OpenVPN	Remote Access VPN	완료
Log Analyzer	rsyslog+MySQL+LogAnalyzer	Web-DB·PMM·WAZUH 로그 수집	완료

2. GNS3 네트워크 구성 검증

네트워크 계층은 GNS3로 구성하였다. 외부망은 3대의 스위치(ESW1~3)를 트렁크로 연결하고 VLAN 10/20/30을 할당하여 공격자 유형별로 브로드캐스트 도메인을 분리하였으며, 내부망은 R1/R2/R3와 ASAv 방화벽으로 라우팅 경로를 구성하였다. 외부망↔내부망 통과 구간(ASAv↔R3)에는 원래 임시 라우터를 두었다가, 트래픽을 그대로 통과시키면서 감시만 하도록 **Suricata 투명 브리지**로 교체하였다.

검증은 두 방향으로 수행하였다. 먼저 각 스위치에서 `show interfaces trunk`·`show vlan-switch brief`로 트렁크 포트 방향과 VLAN 할당을 확인하고, 동일 VLAN 간 ping으로 L2 통신을 검증하였다. 다음으로 R1/R2/R3/NIDS에서 `show ip route`와 구간별 ping으로 L3 라우팅 경로와 도달성을 확인하였다.

2.1 외부망 트렁크 / VLAN 할당

```
ESW2#show interface trunk

Port        Mode         Encapsulation  Status        Native vlan
Fa1/1       on           802.1q         trunking      1
Fa1/2       on           802.1q         trunking      1

Port        Vlans allowed on trunk
Fa1/1       1-4094
Fa1/2       1-4094

Port        Vlans allowed and active in management domain
Fa1/1       1,10,20,30
Fa1/2       1,10,20,30

Port        Vlans in spanning tree forwarding state and not pruned
Fa1/1       none
Fa1/2       none
```

ESW2 show interfaces trunk (f1/2→R3, f1/1→ESW1)

```
ESW3#
ESW3#show interface trunk

Port        Mode         Encapsulation  Status        Native vlan
Fa1/2       on           802.1q         trunking      1

Port        Vlans allowed on trunk
Fa1/2       1-4094

Port        Vlans allowed and active in management domain
Fa1/2       1,10,30

Port        Vlans in spanning tree forwarding state and not pruned
Fa1/2       1,10,30
```

ESW3 show interfaces trunk (f1/2→ESW1)

```
ESW1#show interface trunk

Port        Mode         Encapsulation  Status        Native vlan
Fa1/2       on           802.1q         trunking      1
Fa1/3       on           802.1q         trunking      1

Port        Vlans allowed on trunk
Fa1/2       1-4094
Fa1/3       1-4094

Port        Vlans allowed and active in management domain
Fa1/2       1,10,20,30
Fa1/3       1,10,20,30

Port        Vlans in spanning tree forwarding state and not pruned
Fa1/2       1,10,20,30
Fa1/3       1,10,20,30
```

ESW1 show interfaces trunk (f1/2→ESW2, f1/3→ESW3)

```
ESW1#show vlan-switch brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa1/4, Fa1/5, Fa1/6, Fa1/7
                                                Fa1/8, Fa1/9, Fa1/10, Fa1/11
                                                Fa1/12, Fa1/13, Fa1/14, Fa1/15
10   network                          active
20   system                           active    Fa1/0
30   pentest                          active    Fa1/1
1002 fddi-default                     act/unsup
1003 token-ring-default               act/unsup
1004 fddinet-default                  act/unsup
1005 trnet-default                    act/unsup
```

ESW1 show vlan-switch brief

```
ESW2#show vlan-switch brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa1/3, Fa1/4, Fa1/5, Fa1/6
                                                Fa1/7, Fa1/8, Fa1/9, Fa1/10
                                                Fa1/11, Fa1/12, Fa1/13, Fa1/14
                                                Fa1/15
10   network                          active    Fa1/0
20   system                           active
30   pentest                          active
1002 fddi-default                     act/unsup
1003 token-ring-default               act/unsup
1004 fddinet-default                  act/unsup
1005 trnet-default                    act/unsup
```

ESW2 show vlan-switch brief

```
ESW3#show vlan-switch brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa1/3, Fa1/4, Fa1/5, Fa1/6
                                                Fa1/7, Fa1/8, Fa1/9, Fa1/10
                                                Fa1/11, Fa1/12, Fa1/13, Fa1/14
                                                Fa1/15
10   network                          active    Fa1/0
30   pentest                          active    Fa1/1
1002 fddi-default                     act/unsup
1003 token-ring-default               act/unsup
1004 fddinet-default                  act/unsup
1005 trnet-default                    act/unsup
```

ESW3 show vlan-switch brief

2.2 동일 VLAN 통신 검증

```
PC10> show ip

NAME        : PC10[1]
IP/MASK     : 10.10.10.10/26
GATEWAY     : 10.10.10.1
DNS         :
MAC         : 00:50:79:66:68:09
LPORT       : 10038
RHOST:PORT  : 127.0.0.1:10039
MTU:        : 1500

PC10> ping 10.10.10.20
84 bytes from 10.10.10.20 icmp_seq=1 ttl=64 time=0.916 ms
84 bytes from 10.10.10.20 icmp_seq=2 ttl=64 time=1.070 ms
84 bytes from 10.10.10.20 icmp_seq=3 ttl=64 time=0.978 ms
84 bytes from 10.10.10.20 icmp_seq=4 ttl=64 time=0.976 ms
84 bytes from 10.10.10.20 icmp_seq=5 ttl=64 time=0.979 ms
```

Kali → Attacker-A ping (VLAN10)

```
PC14> show ip

NAME        : PC14[1]
IP/MASK     : 10.10.10.140/26
GATEWAY     : 10.10.10.129
DNS         :
MAC         : 00:50:79:66:68:0d
LPORT       : 10044
RHOST:PORT  : 127.0.0.1:10045
MTU:        : 1500

PC14> ping 10.10.10.130
84 bytes from 10.10.10.130 icmp_seq=1 ttl=64 time=0.626 ms
84 bytes from 10.10.10.130 icmp_seq=2 ttl=64 time=0.792 ms
84 bytes from 10.10.10.130 icmp_seq=3 ttl=64 time=0.814 ms
84 bytes from 10.10.10.130 icmp_seq=4 ttl=64 time=0.820 ms
84 bytes from 10.10.10.130 icmp_seq=5 ttl=64 time=0.717 ms
```

Attacker-D → Attacker-B ping (VLAN30)

```
ESW1#show vlan-switch brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa1/5, Fa1/6, Fa1/7, Fa1/8
                                                Fa1/9, Fa1/10, Fa1/11, Fa1/12
                                                Fa1/13, Fa1/14, Fa1/15
10   network                          active
20   system                           active    Fa1/0
30   pentest                          active    Fa1/1
1002 fddi-default                     act/unsup
1003 token-ring-default               act/unsup
1004 fddinet-default                  act/unsup
1005 trnet-default                    act/unsup
```

외부망 VLAN 통신 확인

```
VPCS> ping 192.168.16.1
84 bytes from 192.168.16.1 icmp_seq=1 ttl=253 time=39.312 ms
84 bytes from 192.168.16.1 icmp_seq=2 ttl=253 time=35.000 ms
84 bytes from 192.168.16.1 icmp_seq=3 ttl=253 time=32.502 ms
84 bytes from 192.168.16.1 icmp_seq=4 ttl=253 time=27.157 ms
84 bytes from 192.168.16.1 icmp_seq=5 ttl=253 time=33.376 ms

VPCS> ping 192.168.0.1
84 bytes from 192.168.0.1 icmp_seq=1 ttl=253 time=40.804 ms
84 bytes from 192.168.0.1 icmp_seq=2 ttl=253 time=34.573 ms
84 bytes from 192.168.0.1 icmp_seq=3 ttl=253 time=33.487 ms
84 bytes from 192.168.0.1 icmp_seq=4 ttl=253 time=30.609 ms
84 bytes from 192.168.0.1 icmp_seq=5 ttl=253 time=31.989 ms
```

Kali-Attacker ping 확인

2.3 내부망 라우팅 / 도달성 검증

```
R1#ping 1.1.1.2

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 1.1.1.2, timeout is 2 seconds:
.!!!!
Success rate is 80 percent (4/5), round-trip min/avg/max = 12/22/52 ms
```

R1 → ASAv-FW(G0/0) ping

```
R2#ping 2.2.2.2

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 2.2.2.2, timeout is 2 seconds:
.!!!!
Success rate is 80 percent (4/5), round-trip min/avg/max = 8/16/32 ms
```

R2 → ASAv-FW(G0/2) ping

```
ciscoasa# ping 3.3.3.2
Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 3.3.3.2, timeout is 2 seconds:
!!!!!
Success rate is 100 percent (5/5), round-trip min/avg/max = 1/26/80 ms
ciscoasa#
```

ASAv-FW → NIDS(f0/0) ping

```
NIDS#ping 4.4.4.2

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 4.4.4.2, timeout is 2 seconds:
!!!!!
Success rate is 100 percent (5/5), round-trip min/avg/max = 8/12/24 ms
```

NIDS → R3(s0/0) ping

```
R1#show ip route
Codes: C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route

Gateway of last resort is 1.1.1.2 to network 0.0.0.0

     1.0.0.0/24 is subnetted, 1 subnets
C       1.1.1.0 is directly connected, FastEthernet0/1
C    192.168.16.0/24 is directly connected, FastEthernet0/0
S*   0.0.0.0/0 [1/0] via 1.1.1.2
```

R1 show ip route

```
R2#show ip route
Codes: C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route

Gateway of last resort is 2.2.2.2 to network 0.0.0.0

     2.0.0.0/24 is subnetted, 1 subnets
C       2.2.2.0 is directly connected, FastEthernet0/1
C    192.168.0.0/24 is directly connected, FastEthernet0/0
S*   0.0.0.0/0 [1/0] via 2.2.2.2
```

R2 show ip route

```
R3#show ip route
Codes: C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route

Gateway of last resort is 4.4.4.1 to network 0.0.0.0

     4.0.0.0/24 is subnetted, 1 subnets
C       4.4.4.0 is directly connected, Serial0/0
     10.0.0.0/26 is subnetted, 3 subnets
C       10.10.10.0 is directly connected, FastEthernet0/0.10
C       10.10.10.64 is directly connected, FastEthernet0/0.20
C       10.10.10.128 is directly connected, FastEthernet0/0.30
S*   0.0.0.0/0 [1/0] via 4.4.4.1
```

R3 show ip route

```
NIDS#show ip route
Codes: C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2
       i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
       ia - IS-IS inter area, * - candidate default, U - per-user static route
       o - ODR, P - periodic downloaded static route

Gateway of last resort is not set

     1.0.0.0/24 is subnetted, 1 subnets
S       1.1.1.0 [1/0] via 3.3.3.1
     2.0.0.0/24 is subnetted, 1 subnets
S       2.2.2.0 [1/0] via 3.3.3.1
     3.0.0.0/24 is subnetted, 1 subnets
C       3.3.3.0 is directly connected, FastEthernet0/0
     4.0.0.0/24 is subnetted, 1 subnets
C       4.4.4.0 is directly connected, Serial0/0
     10.0.0.0/24 is subnetted, 1 subnets
S       10.10.10.0 [1/0] via 4.4.4.2
S    192.168.0.0/16 [1/0] via 3.3.3.1
```

NIDS show ip route

3. DNS 서비스 (BIND9)

서버 구축은 이름 해석 기반을 먼저 마련하기 위해 DNS부터 진행하였다. Ubuntu Server에 netplan으로 고정 IP(192.168.16.91)를 부여하고 BIND9로 정방향 Zone(`lab.local` → IP)과 역방향 Zone(IP → 이름)을 구성하였다. 이후 구축하는 모든 서버를 도메인으로 등록하여, IP가 아닌 이름으로 서버 간 통신·모니터링·로그 식별이 가능하도록 하였다.

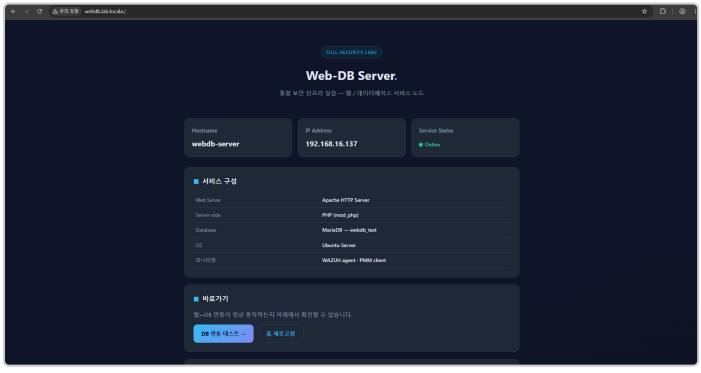
각 레코드는 `named-checkzone`으로 문법을 검증한 뒤 반영하였고, 다른 서버에서 `nslookup`으로 조회가 정상 응답하는지 확인하였다. 정방향과 역방향을 1:1로 맞춰 역방향 조회(PTR)도 동작하도록 정합성을 유지하였다.

```
;
$TTL    604800
@       IN      SOA     localhost. root.localhost. (
                              1         ; Serial
                         604800         ; Refresh
                          86400         ; Retry
                        2419200         ; Expire
                         604800 )       ; Negative Cache TTL
;
@       IN      NS      ns.lab.locala.
91      IN      PTR     ns.lab.locala.
137     IN      PTR     webdb.lab.locala.
221     IN      PTR     wazuh.lab.locala.
139     IN      PTR     zabbix.lab.locala.
201     IN      PTR     pmm.lab.locala.
71      IN      PTR     kali.lab.locala.
48      IN      PTR     earth.lab.locala.
24      IN      PTR     pfsense.lab.locala.
137     IN      PTR     rsyslog.lab.locala.
~
```

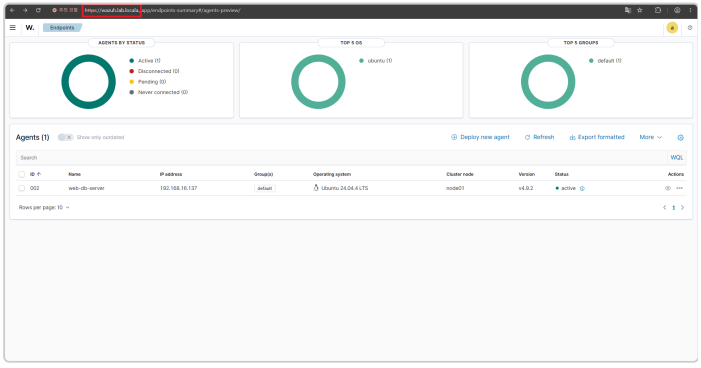
정방향(A) 레코드 — 전 서버 도메인 등록

```
;
; BIND data file for local loopback interface
;
$TTL    604800
@       IN      SOA     localhost. root.localhost. (
                              2         ; Serial
                         604800         ; Refresh
                          86400         ; Retry
                        2419200         ; Expire
                         604800 )       ; Negative Cache TTL
;
@       IN      NS      ns.lab.local.
ns      IN      A       192.168.16.91
webdb   IN      A       192.168.16.137
wazuh   IN      A       192.168.16.221
zabbix  IN      A       192.168.16.139
pmm     IN      A       192.168.16.201
kali    IN      A       192.168.16.71
earth   IN      A       192.168.16.48
pfsense IN      A       192.168.16.24
rsyslog IN      A       192.168.16.137
~
```

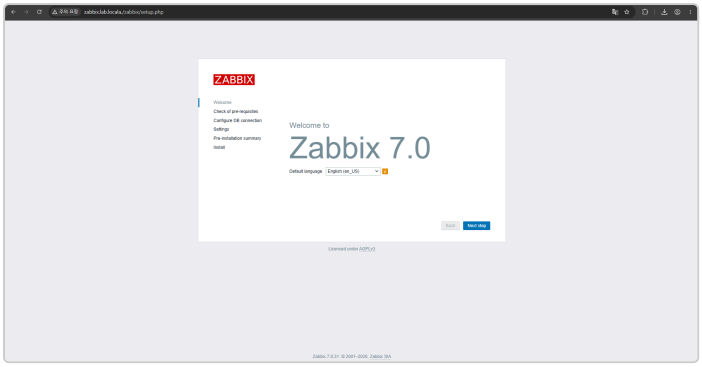
역방향(PTR) 레코드 등록



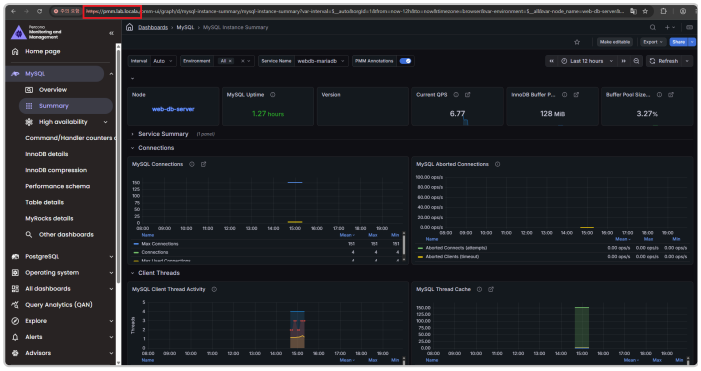
nslookup webdb.lab.local 조회



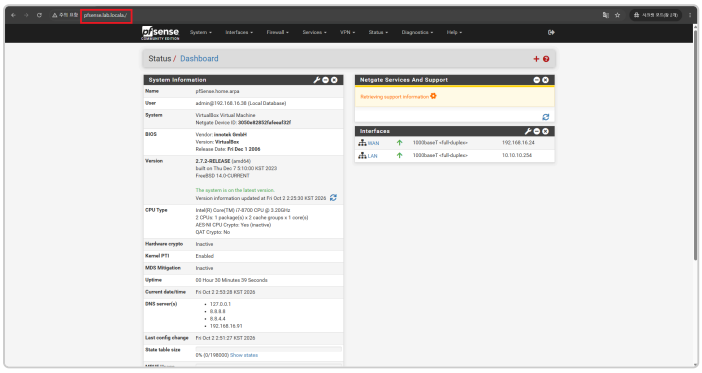
nslookup wazuh.lab.local 조회



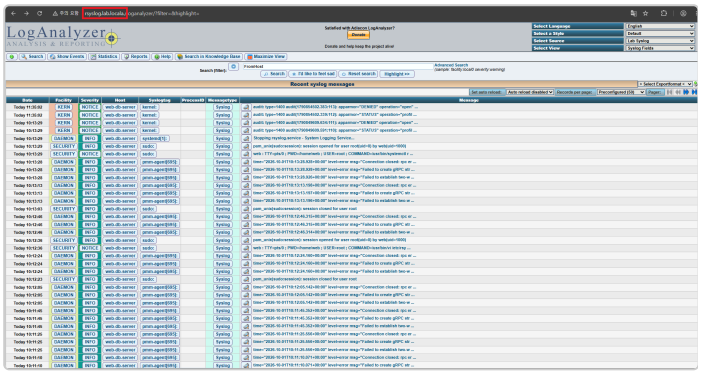
nslookup zabbix.lab.local 조회



nslookup pmm.lab.local 조회



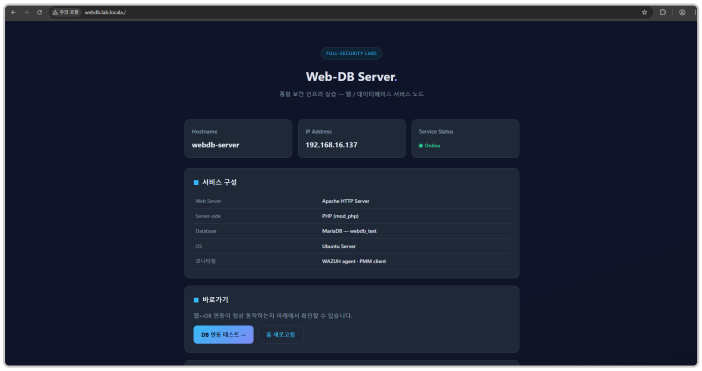
nslookup pfsense.lab.local 조회



nslookup loganalyzer.lab.local 조회 (rsyslog/Log Analyzer)

4. Web-DB 서비스

Web-DB 서버에는 Apache + PHP + MariaDB(LAMP)를 설치하여 웹과 데이터베이스를 함께 운영하였다. 방화벽·IDS 룰 테스트 시 HTTP와 DB 트래픽을 동시에 발생시킬 수 있도록 테스트 페이지(`dbtest.php`)를 두었고, 서비스 공개용 홈페이지(index.html)를 배포하였다. `dbtest.php`는 PHP에서 MariaDB로 접속을 시도해 "DB 연결 성공" 메시지를 반환하며, 이를 통해 웹↔DB 연동이 정상임을 확인하였다.



Web-DB 서비스 홈페이지



dbtest.php — 웹↔DB 연동('DB 연결 성공')

5. 방화벽(ASAv-FW) 정책 및 검증

외부망과 내부망 경계에 Cisco ASAv 방화벽을 배치하고, **"필요한 서비스만 최소 포트로 공개하고 나머지는 차단+로그"** 원칙으로 5개의 접근제어 룰을 설계하였다. 특히 룰4는 관리망(VLAN10)만 ICMP를 허용하여 운영 편의를 제공하면서도 다른 VLAN의 ping 정찰을 차단하고, 룰5는 취약 VM이 있는 DMZ 구간이 침해되더라도 WAZUH 에이전트 포트 외에는 내부망으로 접근하지 못하게 하여 **침해 확산을 방지**한다.

각 룰은 ASA의 `packet-tracer` 명령으로 가상 패킷을 흘려 ALLOW/DROP 판정을 확인하고, 룰4는 Kali(VLAN10)와 Attacker-D(VLAN30)에서 실제 ping을 보내 허용/차단을 교차 검증하였다.

#	정책(방향·대상)	의도	검증
1	outside → Web-DB TCP 80 허용	웹 서비스 공개	**ALLOW**
2	outside → DNS UDP 53 허용	DNS 서비스 공개	**ALLOW**
3	outside → pfSense UDP 1194 허용	원격 접속 VPN	**ALLOW**
4	VLAN10만 ICMP 허용, 그 외 차단+로그	관리망만 ping	Kali **성공** / Attacker-D **차단**
5	DMZ는 WAZUH 포트만 허용, 내부 차단	침해 확산 방지	1514-1515 **ALLOW** / 80 **DROP**

```
# Rule1 웹 서비스 허용
ciscoasa# packet-tracer input outside tcp 10.10.10.140 1234 192.168.16.5 80
  access-list OUTSIDE_IN extended permit tcp any host 192.168.16.5 eq www
  Action: allow

# Rule2 DNS 서비스 허용 (ACL permit — 정상 DNS 질의 허용)
ciscoasa# packet-tracer input outside udp 10.10.10.140 1234 192.168.16.2 53
  access-list OUTSIDE_IN extended permit udp any host 192.168.16.2 eq domain
  Action: allow (ACL)

# Rule3 원격접속 VPN(OpenVPN) 허용
ciscoasa# packet-tracer input outside udp 10.10.10.140 1234 192.168.0.2 1194
  access-list OUTSIDE_IN extended permit udp any host 192.168.0.2 eq 1194
  Action: allow

# Rule4 관리망(VLAN10) 외 차단 + 로그
ciscoasa# packet-tracer input outside tcp 10.10.10.10 1234 192.168.16.4 22
  access-list OUTSIDE_IN extended deny ip any any log
  Action: drop  (acl-drop)

# Rule5 DMZ 격리 — WAZUH 에이전트 포트(1514-1515)만 허용
ciscoasa# packet-tracer input dmz tcp 192.168.0.3 1234 192.168.16.7 1514
  access-list DMZ_IN extended permit tcp 192.168.0.0 255.255.255.0 host 192.168.16.7 range 1514 1515
  Action: allow
# Rule5 — 내부 서버(웹 80) 접근은 차단
ciscoasa# packet-tracer input dmz tcp 192.168.0.3 1234 192.168.16.5 80
  access-list DMZ_IN extended deny ip 192.168.0.0 255.255.255.0 192.168.16.0 255.255.255.0 log
  Action: drop  (acl-drop)
```

※ 위 packet-tracer의 IP(Web-DB 16.5·DNS 16.2·pfSense 0.2)는 GNS3 룰 검증 당시의 주소이며, 실제 서버는 통일 대역(Web-DB .137·DNS .91)으로 운영한다.

```
VPCS> ping 192.168.16.1
84 bytes from 192.168.16.1 icmp_seq=1 ttl=253 time=52.212 ms
84 bytes from 192.168.16.1 icmp_seq=2 ttl=253 time=33.843 ms
84 bytes from 192.168.16.1 icmp_seq=3 ttl=253 time=34.284 ms
84 bytes from 192.168.16.1 icmp_seq=4 ttl=253 time=34.436 ms
84 bytes from 192.168.16.1 icmp_seq=5 ttl=253 time=32.593 ms
```

룰4 — Kali(VLAN10) ping 성공

```
Attacker-D> ping 192.168.16.1
192.168.16.1 icmp_seq=1 timeout
192.168.16.1 icmp_seq=2 timeout
192.168.16.1 icmp_seq=3 timeout
192.168.16.1 icmp_seq=4 timeout
192.168.16.1 icmp_seq=5 timeout
```

룰4 — Attacker-D(VLAN30) ping 차단

```
ciscoasa# show access-list
access-list cached ACL log flows: total 2, denied 2 (deny-flow-max 4096)
            alert-interval 300
access-list TEMP; 1 elements; name hash: 0xfda27108
access-list TEMP line 1 extended permit ip any any (hitcnt=15) 0x0759e6e2
access-list OUTSIDE_IN; 5 elements; name hash: 0xe01d8199
access-list OUTSIDE_IN line 1 remark Rule1 Web
access-list OUTSIDE_IN line 2 extended permit tcp any host 192.168.16.5 eq www (
hitcnt=1) 0x6fa4b4c3
access-list OUTSIDE_IN line 3 remark Rule2 DNS
access-list OUTSIDE_IN line 4 extended permit udp any host 192.168.16.2 eq domai
n (hitcnt=2) 0x04808097
access-list OUTSIDE_IN line 5 remark Rule3 VPN
access-list OUTSIDE_IN line 6 extended permit udp any host 192.168.0.2 eq 1194 (
hitcnt=1) 0x273355d7
access-list OUTSIDE_IN line 7 remark Rule4 VLAN10 ICMP only
access-list OUTSIDE_IN line 8 extended permit icmp 10.10.10.0 255.255.255.192 an
y (hitcnt=0) 0xb5f9050c
access-list OUTSIDE_IN line 9 extended deny ip any any log informational interva
l 300 (hitcnt=1) 0x2dc51227
access-list DMZ_IN; 3 elements; name hash: 0x229557de
access-list DMZ_IN line 1 remark Rule5 DMZ isolation
access-list DMZ_IN line 2 extended permit tcp 192.168.0.0 255.255.255.0 host 192
```

ASAv access-list 구성 (1)

```
.168.16.7 range 1514 1515 (hitcnt=1) 0x540bdd23
access-list DMZ_IN line 3 extended deny ip 192.168.0.0 255.255.255.0 192.168.16.
0 255.255.255.0 log informational interval 300 (hitcnt=1) 0x7070ddaf
access-list DMZ_IN line 4 extended permit ip any any (hitcnt=0) 0xaa95608b
```

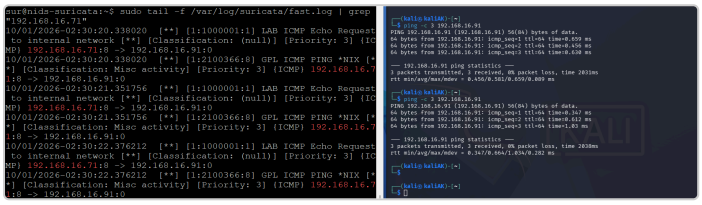
ASAv access-list 구성 (2)

6. NIDS (Suricata) 탐지 룰 및 로그

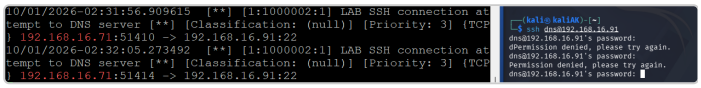
침입 탐지는 Suricata로 구성하였다. 관리용 NIC 1개와 브리지용 NIC 2개를 두고, 브리지 2개를 ASAv↔R3 사이에 끼워 넣어 통과 트래픽을 그대로 흘려보내면서 복제 감시하는 **투명 브리지(탐지 전용, IPS 아님)** 방식으로 배치하였다. 과제 범위가 NIDS이므로 룰은 차단(drop) 없이 `alert`만 사용하였고, HOME_NET은 내부망 192.168.16.0/24로 지정하였다.

임의 룰 3개를 작성하여 실제 트래픽으로 탐지를 검증하였다. 각각 정찰용 ICMP(itype:8), DNS 서버로의 SSH 접속 시도(SYN 플래그), 웹 테스트 페이지(dbtest.php) 접근을 탐지하며, Kali에서 ping·SSH·HTTP를 발생시켰을 때 `fast.log`에 해당 alert가 기록됨을 확인하였다.

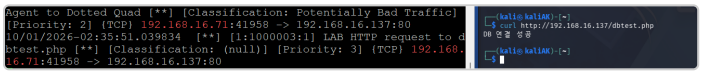
```
alert icmp any any -> $HOME_NET any (msg:"LAB ICMP Echo Request to internal network"; itype:8; sid:1000001;)
alert tcp  any any -> 192.168.16.91 22 (msg:"LAB SSH connection attempt to DNS server"; flow:to_server; flags:S;
sid:1000002;)
alert http any any -> $HOME_NET any (msg:"LAB HTTP request to dbtest.php"; flow:established,to_server; http.uri;
content:"/dbtest.php"; sid:1000003;)
```



SID 1000001 — 내부망 향 ICMP 탐지



SID 1000002 — DNS 서버 SSH 시도 탐지



SID 1000003 — dbtest.php 접근 탐지



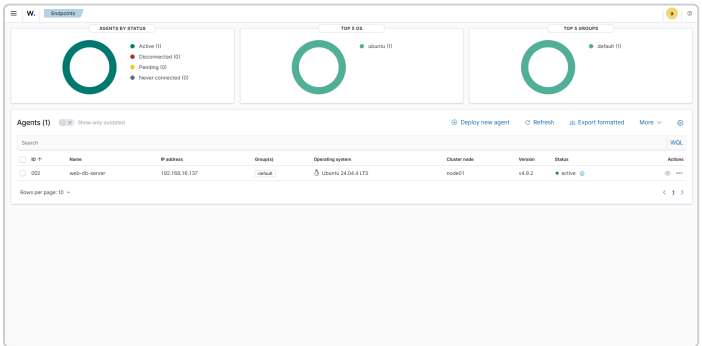
작성한 local.rules 전문

7. SIEM · 모니터링 · 중앙 로그

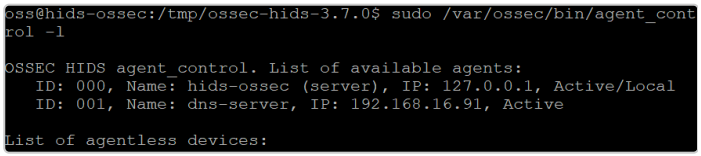
보안관제는 세 축으로 구성하였다. **WAZUH**를 SIEM/HIDS 매니저로 두어 호스트 로그·무결성·보안 이벤트를 수집하고, **Zabbix**로 서버·시스템 가용성(CPU/메모리/서비스)을, **PMM**으로 데이터베이스 성능·쿼리를 모니터링한다. 에이전트는 별도 서버가 아니라 대상 서버에 직접 설치하여, WAZUH agent·PMM client는 Web-DB에, OSSEC(HIDS)·Zabbix agent는 DNS에 배치하였다.

WAZUH 매니저에서 `agent_control -l`로 각 에이전트가 Active 상태인지 확인하고, Zabbix·PMM 웹 콘솔에서 대상 호스트/DB 인스턴스가 정상 수집되는지 확인하였다. 또한 Web-DB의 LAMP를 재사용하여 rsyslog + Adiscon LogAnalyzer로 **중앙 로그 수집기**를 구성하고, Web-DB·PMM·WAZUH의 로그(및 WAZUH alerts.log)를 한 화면에서 조회할 수 있게 하였다.

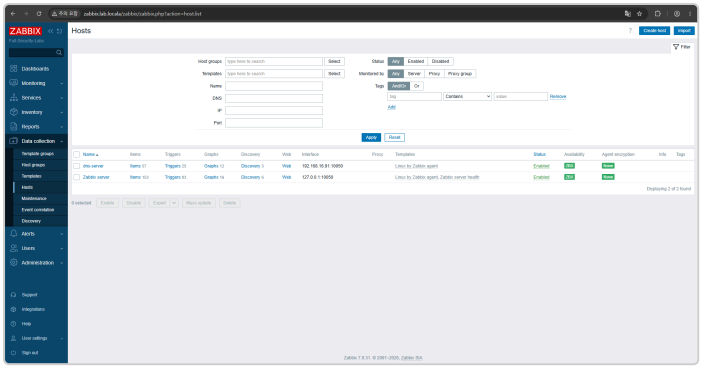
에이전트	설치 위치	리포트 대상
WAZUH agent	Web-DB (192.168.16.137)	WAZUH 매니저 192.168.16.221
OSSEC(HIDS) agent	DNS (192.168.16.91, 관리 .99)	WAZUH 매니저 192.168.16.221
Zabbix agent	DNS (192.168.16.91)	Zabbix 서버 192.168.16.139
PMM client	Web-DB (192.168.16.137)	PMM 서버 192.168.16.201



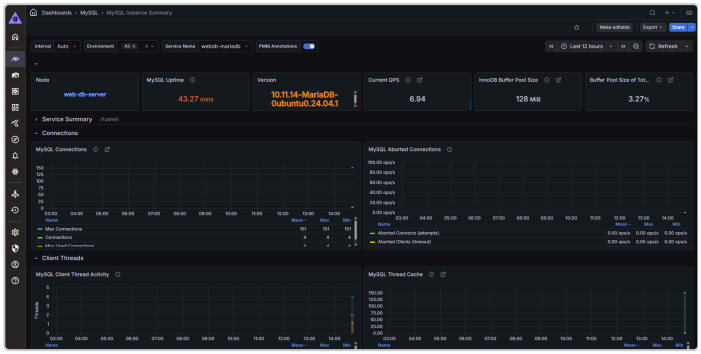
WAZUH 매니저 — 에이전트 등록/Active



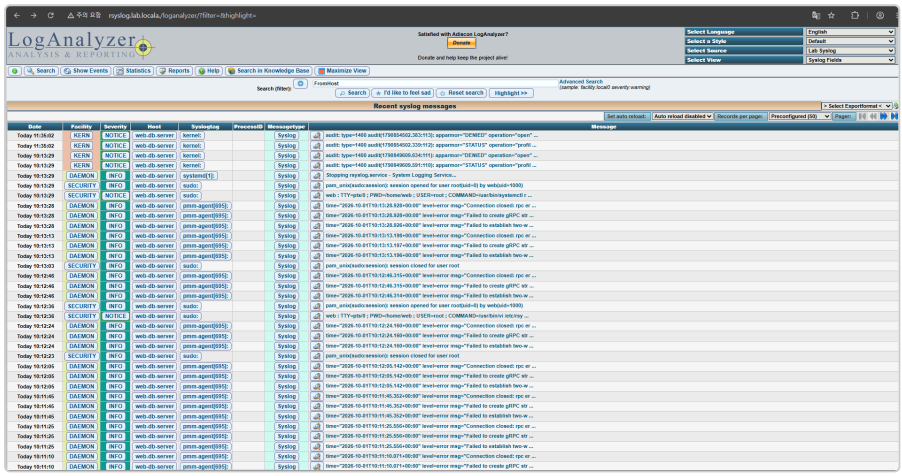
OSSEC(DNS) — 매니저 연동 확인



Zabbix — Host(dns-server) 연동



PMM — Web-DB MySQL 인스턴스 등록

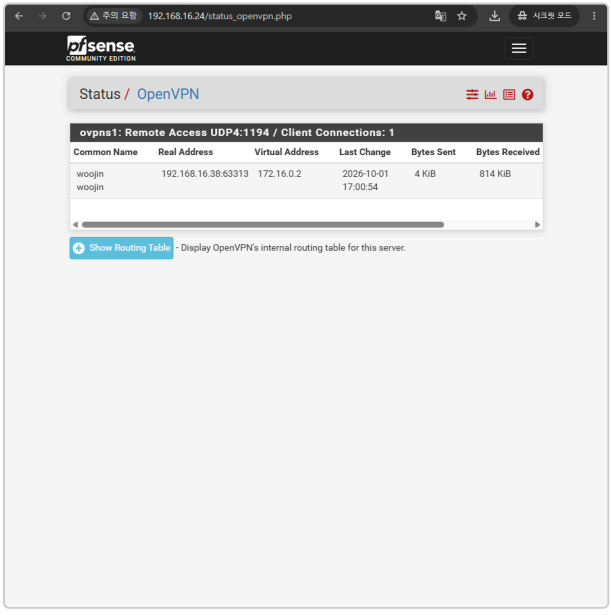


LogAnalyzer — Web-DB·PMM·WAZUH 통합 로그 조회

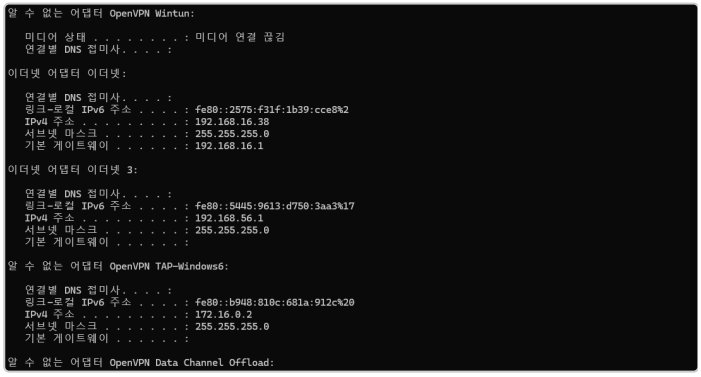
8. 원격접속 VPN (pfSense)

외부에서 내부망 서버에 안전하게 접근할 수 있도록 pfSense로 Remote Access VPN을 구축하였다. FreeBSD 기반 pfSense에 WAN(브리지)·LAN(내부네트워크) 두 어댑터를 두고, 내부 CA → 서버 인증서 → VPN 사용자 순으로 인증 체계를 만든 뒤 OpenVPN 서버를 구성하였다 (프로토콜 UDP 1194, 터널 172.16.0.0/24, 접근 허용 내부망 192.168.16.0/24, 암호 AES-256-GCM).

클라이언트 설정을 내보내 Windows 호스트의 OpenVPN GUI로 접속하였고, 터널 IP(172.16.0.2)가 할당된 뒤 내부망의 DNS·pfSense로 ping이 성공하는 것으로 원격 접속과 내부망 도달을 검증하였다.



서버측 Status>OpenVPN — 세션(172.16.0.2, AES-256-GCM)



클라이언트 OpenVPN 연결 로그(연결됨)

```
C:\Users\Administrator>ping 192.168.16.91

Ping 192.168.16.91 32바이트 데이터 사용:
192.168.16.91의 응답: 바이트=32 시간<1ms TTL=64
192.168.16.91의 응답: 바이트=32 시간<1ms TTL=64
192.168.16.91의 응답: 바이트=32 시간<1ms TTL=64
192.168.16.91의 응답: 바이트=32 시간<1ms TTL=64

192.168.16.91에 대한 Ping 통계:
    패킷: 보냄 = 4, 받음 = 4, 손실 = 0 (0% 손실),
왕복 시간(밀리초):
    최소 = 0ms, 최대 = 0ms, 평균 = 0ms
```

VPN 접속 후 내부 DNS(.91) ping

```
C:\Users\Administrator>ping 192.168.16.24

Ping 192.168.16.24 32바이트 데이터 사용:
192.168.16.24의 응답: 바이트=32 시간=1ms TTL=64
192.168.16.24의 응답: 바이트=32 시간=1ms TTL=64
192.168.16.24의 응답: 바이트=32 시간=1ms TTL=64
192.168.16.24의 응답: 바이트=32 시간<1ms TTL=64

192.168.16.24에 대한 Ping 통계:
    패킷: 보냄 = 4, 받음 = 4, 손실 = 0 (0% 손실),
왕복 시간(밀리초):
    최소 = 0ms, 최대 = 1ms, 평균 = 0ms
```

VPN 접속 후 pfSense LAN ping

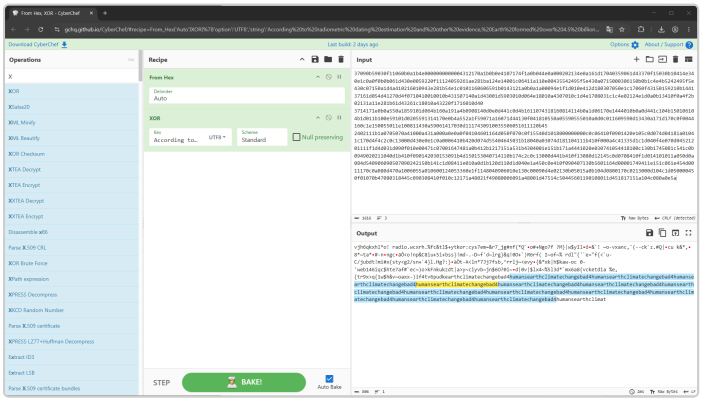
9. 침투 테스트 — CTF (Earth VM)

공격자 관점 검증을 위해 취약 VM(Earth)을 대상으로 정찰부터 권한상승까지 전체 공격 체인을 수행하였다. 각 단계는 실제 공격이 성립하는 원인을 분석하고, 같은 취약점을 어떻게 방어해야 하는지를 함께 정리하였다.

- **정찰**: nmap 전체 포트 스캔으로 22/80/443과 Apache 2.4.51(Fedora)을 확인하고, HTTPS 인증서 SAN에서 가상호스트명(earth.local·terratest.earth.local)을 발견
- **웹 열거**: robots.txt의 `/testingnotes.*`에서 암호 방식(XOR)·키 파일(testdata.txt)·관리자 계정(terra)을 확보하고, gobuster로 관리자 포털(/admin)을 발견
- **암호 분석**: 반복키 XOR + 알려진 평문(known-plaintext) 취약점을 이용해 키를 역산하여 관리자 자격증명을 복원
- **초기 침투·권한 상승**: 관리자 패널의 명령 실행 기능으로 인증 후 RCE(apache)를 얻고, SUID `/usr/bin/reset_root`의 트리거 조건을 분석·충족시켜 root 비밀번호를 재설정 → root 획득

```
# 정찰 → 가상호스트 등록 → 열거
sudo nmap -p- -sV -sC -T4 192.168.16.48 -oN earth_nmap.txt
echo "192.168.16.48 earth.local terratest.earth.local" | sudo tee -a /etc/hosts
curl -sk https://terratest.earth.local/robots.txt        # /testingnotes.*
gobuster dir -u https://earth.local/ -k -w .../big.txt    # /admin 발견
```

단계	취약점	방어 개선안
정보 노출	인증서 SAN·robots.txt로 호스트/파일 노출	민감정보 노출 최소화, 관리 페이지 접근통제(IP 제한·MFA)
암호 취약	반복키 XOR + known-plaintext	표준 검증 암호(AES 등) 사용, 키 재사용 금지
초기 침투	인증 후 임의 명령 실행(RCE)	사용자 입력의 명령 실행 차단(파라미터화·화이트리스트)
권한 상승	SUID reset_root 로직 악용	불필요한 SUID 최소화, 트리거 조건 검증 강화



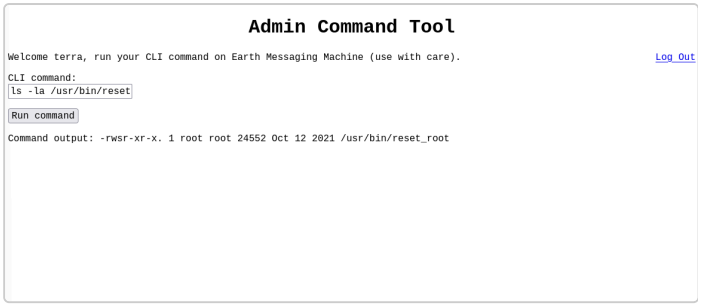
XOR 복호화로 관리자 자격증명 복원



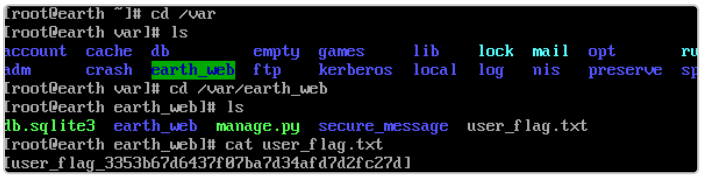
관리자 패널 명령 실행(RCE, whoami=apache)



find로 플래그·SUID 바이너리 탐색



reset_root 트리거 생성 후 실행



user flag 획득



root flag 획득

10. 트러블슈팅 기록

구축·검증 과정에서 마주친 주요 문제와 원인, 해결 방법을 정리하였다. 대부분 "설정은 맞지만 통신 경로·자격증명·검증 절차"에서 발생하였다.

문제	원인	해결
WAZUH 에이전트가 `Never connected`	등록만 되고 매니저 1514/1515 통신 불가(방화벽·키 미입력)	매니저 방화벽 1514/1515 허용, 키 재발급·입력 후 에이전트 재시작 → Active 확인
dbtest.php 접속 시 HTTP 500	php-mysql 미설치 또는 DB 계정/비밀번호 불일치(PHP 8.1 예외)	php-mysql 설치 후 apache 재시작, dbtest.php 자격증명을 실제 값과 일치
pfSense 웹 설정 화면 접속 불가	WAN이 사설대역이라 RFC1918·bogon 차단에 걸림, WAN 기본 차단	Interfaces>WAN의 RFC1918·bogon 차단 해제, 초기엔 `pfctl -d`로 임시 허용
Suricata 룰이 탐지되지 않음	HOME_NET/af-packet 설정 오류 또는 룰 문법 오류	`suricata -T`로 설정 검증 후 재시작, fast.log로 alert 확인
룰/연동이 갑자기 끊김	DHCP로 받은 IP가 재부팅 후 변동	netplan/nmcli로 고정 IP 전환, 서버 대장·DNS 레코드 갱신
ASA 룰2 packet-tracer가 DNS를 drop	임의 UDP 페이로드를 DNS inspect가 무효 패킷으로 판정	ACL은 permit 확인, 실제 `dig` 질의로 정상 응답 재검증

> 공통 원칙: 인라인·방화벽 성격의 변경은 반드시 적용 전 검증(`sshd -t`·`suricata -T`·`named-checkzone`)을 거쳐 서비스 단절을 예방하였다.

11. 결론 및 향후 과제

본 과제를 통해 내부망 서비스(DNS·Web-DB), 보안관제(WAZUH·OSSEC·Zabbix·PMM), 네트워크 탐지(Suricata NIDS), 경계 방화벽(ASAv), 원격 접속(pfSense VPN), 중앙 로그(Log Analyzer), 그리고 외부 공격자망(VLAN 10/20/30)을 하나로 통합한

보안 인프라를 구축하고 검증하였다. 단순 설치에 그치지 않고 방화벽 5개 룰과 Suricata 3개 룰을 실제 트래픽으로 허용/차단·탐지까지 확인하였으며, 모니터링 에이전트를 대상 서버에 직접 배치하여 수집 범위를 명확히 하였다.

또한 Earth CTF로 정보 노출 → 취약 암호 → 인증 후 RCE → SUID 권한상승으로 이어지는 공격 체인을 재현하여, 방어 체계가 왜 필요한지를 공격자 관점에서 확인하고 각 단계별 개선안을 도출하였다.

- **성과**: 네트워크·서버·보안관제·침투 전 영역을 하나의 랩에서 end-to-end로 구성·검증
- **향후 과제**: (1) CTF·정찰 트래픽을 NIDS alert와 WAZUH SIEM 이벤트로 상관분석하는 룰/대시보드 연동 강화, (2) OWASP 웹 취약점 풀이 결과 정리, (3) FW 룰과 NIDS 룰의 운영 중 튜닝(오탐 감소)

> 상세 구축 절차·명령은 노션(구축) 폴더 문서를, GNS3 장비 캡처 원본은 full-security-lab 폴더를 참조.